TECHNICAL STRATEGY / PRODUCT SPECIFICATION

TripRaft
Enterprise Platform
Master Blueprint

One platform for personal travel, corporate travel, and commercial tour agencies

ARCHITECTURE DECISION

One identity and shared core services; multiple workspaces, trip modes, feature entitlements, role policies, and customer-facing experiences. Start with a modular monolith; design tenant isolation, auditability, and approval paths from day one.

Document attribute	Value
Purpose	Product + engineering plan usable for design, implementation, QA, and prioritization
Audience	Founder, product designer, frontend/backend/AI engineers, operations, security
Revision	Version 1.0 - 16 October 2026
Scope	Web-first SaaS; mobile-ready API; personal, business, and agency use cases
Status	Proposed target architecture, not an assertion of current implementation

Prepared with reference to TripRaft project materials and selected public vendor architecture documentation. Exact implementation choices should be validated against the production stack, local travel regulations, payment-provider agreements, and customer requirements.

Executive decision

Do not build three independent trip-planning applications. Build a single TripRaft product platform with shared infrastructure, a stable domain model, and different experiences for travelers, companies, agencies, and operators. Personal and organizational activities must remain logically separate even when one person signs in with one account.

What the user sees

Audience	Primary experience	Important boundaries
Friends / family	Collaborative trip board, maps, polls, itinerary, shared expenses	Private trip; invitation-based access
Corporate employee	Travel requests, approved itineraries, policy status, expenses	Can see own and permitted team travel only
Corporate administrator	Employees, cost centers, travel policies, approvals, reporting	Company workspace data only
Agency operations team	Packages, departures, inventory, suppliers, traveler manifests, finances	Organization-controlled production itinerary
Paying traveler / client	Booking status, itinerary, documents, announcements, request changes	No edit to agency master itinerary
TripRaft internal support	Limited break-glass support, telemetry, billing help	Not a universal customer-data viewer

Non-negotiable platform rules

- User identity is global; memberships and entitlements are contextual to the active workspace and trip.
- Owner, Admin, Member, Viewer are TRIP access roles; Treasurer, Navigator, Culture Scout are assignable responsibilities, not unrestricted power.
- An organization also has its own administrative roles; organization ownership is not trip ownership.
- Every data access and write must be checked for tenant context, trip membership, action privilege, and resource state.
- Publishing or charging money uses explicit approval workflows and auditable state transitions.
- A traveler invited to a commercial departure is different from a staff member editing the product package.

RECOMMENDED STARTING POINT

Next.js/React web app; Python/FastAPI modular backend; PostgreSQL for operations; existing SQLite destination catalog imported or served via catalog API; Redis/worker queue where useful; hosted identity and payment providers. These are recommendations, not requirements.

How to read this document

Chapters 1-9 define the product. Chapters 10-19 define the engineering blueprint. Chapters 20-25 define security, delivery, operations, scenarios, and final decisions. [R#] references are verified external publications; project catalog facts are from the supplied TripRaft SQLite database.

Contents

01 Lessons from large platforms

02 Customer groups and account hierarchy

03 Workspace / tenant model and boundaries
04 Access roles and responsibilities
05 Permission matrix and policy engine
06 Trip modes and business feature flags
07 Friends, family, and individual workflows
08 Corporate and employee travel workflows
09 Agency and commercial tour workflows
10 Customer traveler portal and invitations
11 Trip, package, and departure lifecycles
12 Website structure and information architecture
13 Screen specifications and navigation
14 Technical architecture and service boundaries
15 Database, existing catalog, and data design
16 API contracts and events
17 AI agents and trip assistance
18 Maps, destinations, and availability data
19 Booking, payments, and financial controls
20 Security, privacy, compliance and audit
21 Enterprise administration and provisioning
22 Reliability, performance, and observability
23 Testing and acceptance checklist
24 Roadmap, milestones and prioritization
25 Worked examples, decisions, and references

01 Lessons from large platforms

Different companies solve different commercial problems. Their public descriptions illustrate architectural principles rather than a single template that TripRaft should copy verbatim.

Pattern	Publicly documented example	TripRaft interpretation
Shared multitenant kernel + customer isolation	Salesforce describes a multitenant, metadata-driven platform, with organization IDs on tenant-specific records. [R1]	Use tenant-aware data access and per-organization configuration; do not attempt a Salesforce-sized metadata engine in v1.
Multitenancy is a spectrum	Microsoft documents shared and dedicated deployment choices, and distinguishes B2C/B2B tenants. [R2]	Shared application for most workspaces; premium isolated deployments can be explored if needed.
Centralized authorization	AWS recommends policy administration, decision, and enforcement separation. [R3]	One authorization module enforced at API and background-worker boundaries.
Travel-specific experiences	Expedia TAAP offers an agent-specific booking portal. [R4]	Agency operations portal alongside an intentionally simpler consumer experience.
Specialized financial permissions	SAP Concur documents employee admin, approver, processor, and restricted permissions. [R5]	Separate viewing, preparation, approval, execution, and reconciliation authority.

Principle to copy - not complexity to copy

- Share core capabilities: identities, destinations, itinerary engine, notifications, permissions, files, AI, search.
- Vary customer journeys: a family sees polls; a company sees policy approvals; an agency sees inventory, departures, and manifests.
- Keep payment flows, B2B invoicing, and commercial inventory separate from casual shared-expense flows.
- Use configuration and feature entitlements, not scattered hard-coded if-statements for every enterprise customer.

02 Customer groups and account hierarchy

Four distinct identities

Concept	Meaning	Example
User	A real signed-in identity, global across TripRaft	A person plans family trips and also works for an agency
Workspace / tenant	Isolated customer context: personal workspace or organization	Patel family workspace; Acme Corp; Sunrise Tours
Trip / departure	A planning or operational unit inside a workspace	Family weekend; company retreat; Italy Tour 8 July
Membership	Relationship granting a user or guest scoped access	Employee in Acme; Admin in a specific trip

A person may have multiple workspace memberships. A user can switch workspaces, but switching must change the active tenant context everywhere: UI, API, search, files, analytics, AI tools, and notifications. An organization may own many trips, travel policies, supplier contracts, packages, and departures.

Recommended hierarchy

```
TripRaft identity (one user)
  |-- Personal workspace (user-owned)
  |     +-- Personal trips / invitation groups
  |-- Organization A (corporate tenant)
  |     +-- departments, employees, trips, approvals
  +-- Organization B (agency tenant)
        +-- packages -> departures -> bookings -> travelers
```

Where guests fit

A paying customer may have a customer record and secure booking access before registering a full TripRaft account. Keep traveler/customer identity and staff memberships separate. A booking can include many travelers, who may or may not each have a TripRaft login. Verify email or phone ownership before exposing personal documents.

03 Workspace model and boundaries

Workspace types

Type	Who owns it	Supported functions
PERSONAL	Individual user	Personal trips, inviting friends, polls, budgets, sharing

Type	Who owns it	Supported functions
CORPORATE	Company/authorized organization	Requests, budget controls, department reports, policy approvals
AGENCY	Travel operator/agency	Packages, departures, customer bookings, supplier operations
PARTNER (later)	External supplier or reseller	Contracted allocation, confirmation workflows, limited inventory access

Tenant and ownership invariants

- Every organization-owned record carries org_id / tenant_id or a verifiable ownership chain. Personal trips carry personal workspace scope.
- A unique email address does not grant any membership in another organization.
- Organization Owner can delegate administrative duties and cannot silently read personal trips.
- Trip Owner governs one trip under organizational policy; cannot transfer organization-owned bookings into a personal account.
- Cross-workspace sharing uses explicit guest/grant objects, never a silent join of tenant data.
- All list, export, search, file, and AI retrieval flows must inherit the same access filter.

Tenant isolation strategy

Begin with pooled infrastructure and shared PostgreSQL schemas using tenant identifiers and careful access policies. Add PostgreSQL row-level security where feasible as defense in depth; RLS does not replace application authorization. If future enterprise customers need residency or dedicated environments, add a tenant-to-deployment directory and a separate deployment tier, not a new product. [R2] [R6]

04 Access roles and trip responsibilities

Trip access roles (exact four)

Role	Expected scope	Not automatically allowed
Owner	Final trip control, management, transfer or archive within workspace constraints	Override organization payment, policy, and security controls
Admin	Manage trip membership, operational itinerary, assignments and publication as delegated	Delete organization account; spend funds absent approval
Member	View and participate, comment, propose changes, execute assigned tasks	Publish official changes or disclose confidential financial data
Viewer	Read designated itinerary and updates	Edit, invite, access privileged finance/PII

Assignable responsibilities

Responsibility	Typical tasks	Permission rule
Treasurer	Collect expense evidence; maintain cost estimates; reconcile balances and supplier bills	Can prepare financial actions; execute/refund only with explicit capabilities and approval
Navigator	Routes, transfer times, transport confirmations, meeting points, contingencies	Can draft logistics; cannot change supplier bookings by responsibility alone
Culture Scout	Discover attractions, food, cultural guides, experience recommendations	Can propose additions; cannot publish paid itinerary changes by default

Responsibilities are separate assignment rows. One person can hold multiple responsibilities; more than one person may share a responsibility where the trip permits. Scope assignments by trip and optionally by departure or task. They are displayed as badges, not confused with base access roles.

Organization-level roles are separate

For organizations, use Organization Owner, Organization Admin, Operations Manager, Finance Manager, Employee/Staff, and Auditor as organization membership roles or groups. Do not replace the four trip roles with them. Organization capabilities flow into trip operations only through explicit policy grants.

05 Effective permissions and policy engine

Example baseline matrix

Action	Owner	Admin	Member	Viewer
Read public itinerary	Yes	Yes	Yes	Yes
Suggest / comment	Yes	Yes	Yes	No
Edit itinerary draft	Yes	Yes	If delegated	No
Publish / lock itinerary	Yes*	Yes*	No	No
Invite members	Yes	Yes*	If delegated	No
Assign trip duties	Yes	Yes*	No	No
View confidential margins	Policy	Policy	No	No
Approve supplier payment	Policy	Policy	No	No
Transfer/archive trip	Yes*	No	No	No

* Within organization policy and resource state. In agency mode, the owner may be an organization; an authorized operator performs the action. The table is a baseline, not a replacement for centralized policy decisions.

Authorization decision

```
ALLOW only if:
  authenticated_user
  AND workspace membership / validated guest grant
  AND resource belongs to active workspace
  AND trip or departure membership supports action
  AND base access role OR explicit delegation permits action
  AND feature entitlement permits operation
  AND status + policy + approval gates permit action
  AND resource-specific privacy checks pass
Else DENY and record auditable reason.
```

Permission categories

- trip.read, trip.invite, trip.edit_draft, trip.publish, trip.transfer, trip.archive
- members.manage, responsibility.assign, poll.vote, comments.write
- cost.estimate, expense.create, finance.internal_read, invoice.approve, refund.approve
- booking.view_own, booking.manage, supplier.manage, manifest.read_limited
- org.members.manage, org.policies.manage, org.billing.manage, audit.read

Principles for delegations

Store the who/what/where/until/why of every delegated permission. Scoped capabilities expire or are revoked when the user leaves. A Treasurer label alone never grants financial execution. For high-risk actions, separate preparer, approver, and executor when operations grow.

06 Trip modes and feature entitlements

Mode	Default write policy	Approval focus	Primary monetization
Personal	Collaborative proposals; optional direct coediting	Polls, collective choices, optional owner finalization	Freemium; optional premium planner
Corporate	Request + manager/finance-approved changes	Travel policies, budgets, reimbursements	B2B seats/workspaces and usage
Commercial agency	Package templates + approved live departures	Bookings, pricing, cancellations, supplier commitments	B2B subscription / agency service fees
Education / group	Supervised edits; participant read access	Teacher/leader supervision, itinerary changes	Group organizer tier or enterprise sale

Do not encode industry as permission

Trip mode configures defaults and available modules; an individual user still needs membership and capabilities. Corporate mode does not automatically make every company employee an Admin. Agency mode does not automatically expose customer PII to all staff.

Product plans vs roles

Roles answer “May this actor perform this action?” Entitlements answer “Did this workspace subscribe to this feature/limit?” Keep separate tables for plan, subscription, entitlement, usage meter, and policy. Example: agency reports may be absent on a basic plan even if user is Admin.

07 Friends and family trip workflow

1. User signs up and creates a personal workspace automatically.
2. Creates a trip with destination, dates, budget guidance, currency, and privacy.
3. Invites relatives or friends by verified link or email; assigns Member or Viewer, with optional expiry.
4. Members suggest places from the destination catalog; AI offers an itinerary draft.
5. Culture Scout curates activities, Navigator plans routes, Treasurer collects shared-cost entries.
6. Polls or comments resolve conflicts; Owner/Admin publishes a trip version.
7. During travel, users check itinerary, offline-friendly details, shared announcements, and expenses.
8. After travel, settle balances, export memories/expenses, and archive the trip.

Trip collaboration defaults

- A member may suggest or edit a draft block but not secretly overwrite published bookings.
- A viewer can be a relative who needs the itinerary but will not be editing.
- Invite links must expire and have maximum redemption count; access can be revoked.
- For family travel, support parents/guardians managing dependents without requiring children to register.
- Conflicts in multi-user edits should be shown, not silently lost.

Example: family of 6

SAMPLE ASSIGNMENTS

Parent 1 = Owner + Treasurer; Parent 2 = Admin; Child A = Member + Culture Scout; Child B = Member + Navigator; grandparents = Viewers. The same family may set viewer access to read-only during travel.

08 Corporate travel workflow

9. Company admin creates verified corporate workspace, billing information, cost centers, and travel policies.
10. Employees are invited or provisioned through SSO/SCIM in an advanced tier; manager relationships are assigned.
11. Employee requests destination, purpose, dates, estimated budget, and funding cost center.
12. Policy engine checks category, travel class, amount, dates, and required documentation.
13. Manager and/or Finance approves; a company coordinator creates itinerary and books with authorized suppliers.
14. Employee receives travel documents and updates, but sees only information they are permitted to access.
15. During travel, expenses and incidents follow company workflows.
16. After travel, finance reconciles requests, transactions, receipts, and policy exceptions.

Corporate workflow example

Actor	View	Write / approve
Employee	Own itinerary, request and expense status	Submit request; upload receipts; propose change
Manager	Direct-report requests, limits, policy exceptions	Approve or reject within configured limits
Travel coordinator	Assigned travelers and approved itinerary	Draft bookings / schedule; escalate changes
Finance manager	Budget, invoices, approved supplier data	Approve spending; reconcile and export
Company auditor	Policy history, approved evidence	Read-only exports with audit logging

Policy examples

Travel class caps, hotel nightly limits by region, approval routing by amount, travel purpose required fields, approved suppliers, receipt thresholds, and emergency contact capture. Avoid encoding legal or tax policies directly in the UI; tenant-configurable rules and export reports are safer.

09 Agency and commercial tour workflow

Separate a package from a departure and a booking

```
Tour package (reusable product definition)
 +-- Departure 2027-06-01 (20 seats, operational itinerary)
 |    +-- Booking A (2 travelers, payment state)
 |    +-- Booking B (4 travelers, payment state)
 +-- Departure 2027-06-15 (same package, different dates)
      +-- Booking C (1 traveler)
```

A package describes the product. A departure is a scheduled, capacity-constrained instance. A booking is a customer transaction and participation relationship. These must be distinct tables, not one trip row with all fields mixed together.

Agency end-to-end

17. Agency signs up, verifies business profile and staff access, and configures policies.
18. Product manager drafts a package with itinerary, inclusions/exclusions, departure dates, price components, cancellation rules and minimum group size.
19. Navigator plans transfers; Culture Scout selects attractions; Treasurer models costs and margins.
20. Authorized Admin approves package publication and available inventory.
21. Customers select departure, provide traveler details, accept terms, pay or request reservation as applicable.
22. System creates booking and seat hold with expiry, payment status and confirmation workflow.
23. Operations staff assign guides and vehicles, finalize supplier confirmations, and publish a departure itinerary version.
24. Guides and travelers see correct operational views. Alerts and change acknowledgements are sent.
25. After departure, reconcile supplier invoices, customer refunds, commission and post-trip reports.

Agency must see financial boundaries

Value	Who typically sees it
Customer price & inclusions	Public or customer-facing
Customer payment status	Customer for own booking; authorized agency staff
Supplier net cost / agent commission	Authorized agency operations or finance only
Gross margin / profitability	Agency Owner / Finance manager only
Other clients' passports or private documents	Never exposed to unrelated travelers or unassigned staff

Commercial exception handling

Support waitlist, minimum group size, supplier overbooking, flight disruption, itinerary substitutions, cancellation penalties, customer change requests, room allocations, refund approvals, and disaster recovery. Never mark a third-party booking "confirmed" until an authoritative provider or authorized operator confirms it.

10 Traveler and customer access

A paying traveler is not simply a trip Member with unlimited editor rights. Use a customer booking relationship plus optional Viewer/Traveler portal access. Access is narrowed to that booking, departure, and approved shared group announcements.

Customer portal

- Reservation status and confirmed services, payment schedule, receipt and invoice links.
- Personal documents and traveler information, with purpose-limited collection.
- Daily itinerary, pickup location, guide contact (when allowed), traveler announcements.
- Request a change, report an issue, review cancellation terms, view refund status.
- Optional social/group features only after consent; no default exposure of all traveler identities.

Invitations and access claims

Treat staff invites, friend invites, corporate provisioning, and customer booking links differently. Booking links should be scoped, short-lived, and protected against brute-force enumeration. A claim of booking ownership should require sufficient verification before displaying PII.

11 Lifecycle and state management

Trip lifecycle

```
DRAFT -> PLANNING -> REVIEW -> PUBLISHED -> ACTIVE -> COMPLETED -> ARCHIVED
          |          |          |
          +-> CANCELLED (with cancellation reason and retention policy)
```

Package, departure, and booking lifecycle

Object	States (illustrative)	Key rule
Package	Draft -> Review -> Published -> Retired	Publishing requires authorized review
Departure	Scheduled -> Open -> Closed -> In progress -> Completed	Seat availability and live operations linked to departure
Booking	Initiated -> Held -> Pending payment -> Confirmed -> Fulfilled	Separate cancellation/refund side paths; payment ≠ supplier confirmation
Payment	Created -> Pending -> Succeeded / Failed -> Refunded (partial/full)	Use provider webhooks and reconciliation; never infer from redirect alone
Approval	Pending -> Approved / Rejected / Expired / Withdrawn	Approval validates amount, action, actor and version

Published versions and change policy

Store a version snapshot at each publication. Draft changes do not silently alter confirmed traveler documents. Material operational changes (pickup, hotel, price, safety information) create a change log and require customer notification/acknowledgment as configured. When costs change, approval should bind to the exact quote version and currency.

12 Website architecture and routes

One brand with role-aware route groups

URL example	Audience	Purpose
tripraft.com	Everyone	Marketing, public discovery, plans, safety and support
app.tripraft.com	Logged-in	Workspace switcher and context-aware home
app.tripraft.com/personal/trips	Friends/family	Trip creation and collaboration
app.tripraft.com/org/:slug	Business users	Scoped org overview
app.tripraft.com/org/:slug/requests	Corporate	Travel requests and approvals
app.tripraft.com/org/:slug/packages	Agencies	Package library and publication
app.tripraft.com/org/:slug/departures	Agencies	Live departures, seats, staff, manifests

URL example	Audience	Purpose
app.tripraft.com/bookings/:id	Customer	Scoped traveler/booking portal
app.tripraft.com/trips/:id	Members	Shared trip itinerary and map

These are proposed example paths, not existing production URLs. Share React components, design tokens and API endpoints. Dashboard widgets and navigation are configured by active tenant, membership, trip mode and feature entitlement.

Navigation architecture

```
Public website -> Signup/Login
  -> Workspace selector
    -> Personal dashboard
    -> Company dashboard (requests, team, policy, budgets)
    -> Agency dashboard (packages, departures, bookings, suppliers)
  -> Trip context (itinerary, map, chat, roles, tasks, finance)
```

Responsive design

Use consistent navigation on desktop and mobile. On desktop, present trip map + timeline side by side. On mobile, use itinerary/map tabs and always-visible next-action cards. Customer travelers should never have to navigate back-office package setup screens.

13 Detailed screen specifications

Screen	Core elements	Primary action
Workspace switcher	Personal + organization memberships, role, last active	Choose workspace
Trip dashboard	Dates, members, next item, map, tasks, polls, expenses	Open plan / create trip
Itinerary editor	Day timeline, version badge, proposals, conflicts, approval status	Save draft / submit / publish
Roles & tasks	Access roles, responsibility badges, delegations, expiring invites	Assign / revoke
Corporate requests	Requested trips, policy warnings, approvers, cost centers	Review / approve
Agency package builder	Reusable day templates, inclusions, margins, pricing rules	Submit package
Departure command center	Capacity, bookings, guide roster, payments, incidents	Manage departure
Traveler portal	Reservation, documents, payment schedule, daily plan	View / request change
Organization admin	Users, groups, policies, audit, integrations, billing	Configure workspace

Detailed interaction: creating a trip

26. Ask the user “What kind of trip?” only if the active workspace does not make it obvious.
27. Show mode-dependent fields with sensible defaults, not a huge universal form.
28. Create a draft resource and assign creator scoped Owner or organization-approved role.
29. Ask the user to invite participants and assign responsibilities optionally.
30. Open the itinerary workspace with AI suggestions, destinations, and map markers.
31. Move to published only when the current policy accepts the version.

Design system

Shared visual language across every mode: cards, compact status chips, itinerary timeline, permission-gated action menus, consistent activity log and approval banners. Business users need denser tables and filters; consumers need visual cards and mobile-friendly actions.

14 Technical architecture

Recommended initial stack

Layer	Suggestion	Reason / alternative
Web frontend	Next.js + React + TypeScript	SSR/SEO for public packages; app UI shares components
Backend	FastAPI + Python	Fits AI tooling; typed REST; modular monolith
Transactional DB	PostgreSQL	Integrity, migrations, RLS option, relational domain
Catalog	Existing SQLite -> import to PostgreSQL / read-only catalog service	Reuse validated place IDs and source provenance
Caching / jobs	Redis + task queue or managed queue	Notifications, itinerary builds, scheduled exports
Storage	S3-compatible object storage	Private files, presigned URLs, lifecycle policies
Search	Postgres full text then dedicated search if justified	Start simple; hybrid retrieval later
Auth	OIDC provider with organizations support	Managed MFA, SSO roadmap
Maps / routing	MapLibre or Leaflet UI; licensed tiles + routing provider	Commercial map terms and key security matter
Payments	PSP with marketplace/connect capabilities when needed	Avoid storing card details

Modular monolith modules

```
API Gateway / Web BFF
  Auth | Tenant Context | Policy Engine | Entitlements
  Users | Organizations | Trips | Memberships | Itineraries
  Tasks/Polls | Destination Catalog | AI Planning | Search
  Corporate Policies/Approvals | Packages/Departures/Bookings
  Payments/Finance | Notifications | Files | Audit
```

Each module owns its tables, domain services, and events. Use one deployable backend initially; split modules into separate services only where scaling, organizational autonomy, or reliability requirements justify the extra operations overhead.

Asynchronous jobs

Trip plan AI generation, notifications, route recalculation, supplier polling, payment reconciliation, email delivery, exports and analytics are candidates for a background queue. Job payloads must carry verified tenant scope and re-authorize sensitive actions; never trust client-supplied tenant IDs.

15 Data model and existing TripRaft catalog

Verified current-state catalog (supplied SQLite)

Inspection of tripraft-canonical.db on 16 October 2026 shows: 190 countries, 1,739 states, 3,380 cities, 22,925 places, 315 airports, and 673 festival rows. Existing tables include places, place_search_fts, photos, opening_hours, data_sources, provider_references and verification tables. Place search FTS has 22,925 rows. This database is a destination/content catalog, NOT a user/trip/agency operational database.

Existing entity	Count / purpose	Integration
countries, states, cities	190 / 1,739 / 3,380	Destination drilldown and browsing
places	22,925	Canonical place_id in itinerary stops
airports	315	Transport reference
festivals	673	Culture Scout event recommendations
photos, photo_attributions	Place media and license metadata	Attribute and filter licensed visual assets
place_search_fts	22,925 indexed rows	Text search, ranking and suggestions
data_sources, field_verifications	Source lineage / verification	Show confidence; periodic review

New operational entities to add

Domain	Proposed tables
Identity & tenancy	users, workspaces, organizations, organization_memberships, invitations, external_guests
Trips & permissions	trips, trip_memberships, trip_responsibilities, capability_grants, trip_versions
Itinerary & collaboration	itinerary_days, itinerary_items, itinerary_proposals, polls, votes, comments, tasks
Commercial	tour_packages, package_versions, departures, departure_inventory, bookings, booking_travelers, supplier_reservations
Corporate	travel_policies, travel_requests, approvals, cost_centers, manager_assignments
Finance	expenses, expense_splits, ledger_entries, payment_intents, refunds, invoices
Audit & platform	audit_events, notifications, outbox_events, feature_entitlements, webhooks

Data constraints and ownership

- Every trip belongs to exactly one workspace; a workspace is Personal, Corporate, or Agency (with extensible type).
- A package belongs to an agency workspace; departures belong to packages; bookings belong to departures.
- Store currency as ISO code and money as integer minor units or explicit decimal NUMERIC, never floating-point.
- Store local event dates/timezones separately from UTC timestamps, and show timezone in itinerary UI.
- Refer to catalog places with immutable stable IDs; preserve user-added custom places separately.
- Keep sensitive travel documents in private object storage, not public URLs or general AI vectors.

Illustrative SQL

```
CREATE TABLE workspaces (
  id UUID PRIMARY KEY, kind TEXT NOT NULL, name TEXT NOT NULL,
  owner_user_id UUID, created_at TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE TABLE trips (
  id UUID PRIMARY KEY, workspace_id UUID NOT NULL REFERENCES workspaces(id),
  mode TEXT NOT NULL, title TEXT NOT NULL, status TEXT NOT NULL,
  start_date DATE, end_date DATE, created_by UUID NOT NULL
);
CREATE TABLE trip_memberships (
  trip_id UUID NOT NULL REFERENCES trips(id), user_id UUID NOT NULL,
  access_role TEXT NOT NULL CHECK (access_role IN
    ('owner','admin','member','viewer')),
  PRIMARY KEY (trip_id, user_id)
);
```

DDL is deliberately illustrative: add actual referenced user tables, tenant consistency constraints, cascading/soft-delete strategy, unique indexes, audit triggers or events, and migration tests before production.

16 API and integration contracts

Representative endpoints

Method	Route	Required control
POST	/v1/workspaces	Signed in + ownership policy
GET	/v1/workspaces/{id}/trips	Active workspace membership and tenant filter
POST	/v1/trips	Workspace create permission + mode entitlement
PATCH	/v1/trips/{id}/draft	trip.edit_draft + version check
POST	/v1/trips/{id}/publish	trip.publish + approval/version gate
POST	/v1/trips/{id}/members	members.manage + invite policy
POST	/v1/trips/{id}/responsibilities	responsibility.assign
POST	/v1/travel-requests	corporate member + policy checks
POST	/v1/approvals/{id}/decision	named current approver + state guard
POST	/v1/packages/{id}/departures	agency operations capability
POST	/v1/departures/{id}/bookings	inventory hold + customer entitlement
POST	/v1/payment-webhooks/provider	provider signature + replay protection

API request context

```
POST /v1/trips  (authenticated request)
{
  "workspace_id": "verified-active-workspace-uuid",
  "title": "Japan Family Vacation",
  "mode": "personal",
  "start_date": "2027-04-07", "end_date": "2027-04-13"
}
Response: 201 + trip_id + draft status + allowed_actions[]
```

Important: workspace_id is never trusted simply because it appears in a request. The server validates that the caller can create trips in that workspace. For mutation requests use idempotency keys where repeat submissions could create financial, booking, or invitation side effects.

Event-driven boundaries

Use an outbox table/event publisher for durable domain events such as trip.published, invite.accepted, request.approved, booking.confirmed, payment.succeeded and trip.change_acknowledgment_required. Consumers should be idempotent. Reconcile provider state rather than assuming event arrival order.

17 AI trip assistant and agents

Safe agent separation

Agent capability	Inputs	Allowed outputs
Scout / discovery	Catalog, user preferences, allowed public sources	Place recommendations with citations, confidence and place IDs
Navigator assistant	Geocoded stops, provider route info, user constraints	Route proposals and transfer buffers
Culture assistant	Catalog category, events, local sources	Attractions, customs, accessibility prompts
Treasurer assistant	Authorized expenses, trip budget, exchange-rate provider	Cost breakdowns, draft settlements and anomaly flags
Coordinator / planner	Trip state, policies, validated proposals	Itinerary draft, tasks and requests for human approval

AI permission envelope

The model can suggest but cannot grant itself privileges. Before each tool action, evaluate the acting user's effective permission, workspace, trip, and data scope. A Culture Scout agent can draft activity proposals; it cannot publish a paid departure itinerary or change a booking without explicit approval. Retrieval filters must enforce tenant and document visibility.

Agentic workflow

```
User request -> Intent + scope check -> Retrieve permitted catalog/data
  -> Plan draft -> Tool proposals -> Policy evaluation
  -> Human approval for material or financial actions
  -> Execute idempotent tool -> Verify supplier/result
  -> Save event/audit trail -> Notify affected people
```

AI evaluation

Maintain offline test suites for grounded place IDs, route plausibility, permission refusals, hallucinated booking status, currency calculation, PII exposure, and tool retry behavior. Monitor tool-call error rate, acceptance rate, edited suggestions, per-plan cost and human override rate. For business workflows use deterministic validation before any state-changing tool.

18 Maps, catalog, and destination search

What TripRaft already owns

Its global place catalog provides country/state/city/place hierarchy, location fields, available attraction metadata, photo/license records, tags, search index and provenance. TripRaft can render these pins without paying a commercial places API for each known attraction. However, provider licenses, freshness and incomplete records still require verification.

Map stack

Concern	Component	Important rule
Interactive map renderer	MapLibre GL JS or Leaflet	Open source library is not the map-data provider
Tile basemap	Commercially permitted public/paid/self-hosted tile provider	Check fair use, attribution, SLA and production terms
Routing / ETA	Routing API or OSRM/Valhalla self-hosting	Route results are separate from tiles
Geocoding/autocomplete	Geoapify, Photon, Nominatim compliant deployment, etc.	Each service has its own usage and caching terms
Markers	TripRaft canonical place catalog	Use stable IDs, verify coordinates
Operating hours and tickets	Catalog with freshness metadata + external validation	Do not claim real-time open/booking availability without source

Catalog operations

- Keep source_id, verification_status, verified_at and usage license details when importing data.
- Update attractions separately from operational trip data; a changed attraction name must not rewrite historical confirmed receipts.
- Offer fallback manual places with clear distinction from catalog entities.
- Provide confidence indicators and a “last verified” message for stale hours/prices.
- Do not make photos public unless applicable attribution and license terms permit display.

19 Financial, booking, and supplier operations

Separate four kinds of money

Money flow	Personal mode	Business / agency mode
Shared expenses	Friends reimburse friends; no marketplace funds held by default	Not the same as customer sales
Customer collection	Usually not applicable	Booking payment, tax and refund records
Supplier settlement	Usually external booking directly	Authorized payout, invoice and reconciliation
Platform revenue	Subscription or premium service fee	Subscription / transaction service fees if contracted

Payment safety

- Use an established payment service provider; do not store full card details.

- Make payment initiation and webhook processing idempotent, verify webhook signatures and preserve an append-only ledger of financial transitions.
- Do not accept booking confirmation until inventory and supplier state are verified.
- Limit refund approval and execution to financial capabilities with thresholds.
- For marketplaces or agency payouts, determine merchant-of-record and legal responsibilities before choosing Connect-style flows. [R8]
- Support multi-currency presentation but record authoritative transaction currency and conversion provenance.

Inventory consistency

Use expiring seat holds and an atomic transaction to prevent overselling a departure. Supplier confirmation may be asynchronous; expose pending vs confirmed distinctly. A cancellation must release seats only according to inventory rules and external reservation state. Model rooms, vehicles and guide capacity as separate inventory classes if the product needs them.

Refund approval example

```
Traveler requests refund
 -> Policy computes eligible amount and penalty
 -> Agent/Treasurer prepares case
 -> Authorized approver reviews source booking + exact amount
 -> PSP action with idempotency key
 -> Verified webhook -> Ledger + traveler status + audit event
```

20 Security, privacy, and governance

Critical threats

Risk	Minimum mitigation
Cross-tenant data leak	Verified workspace context in every query; deny-by-default tests; object-level checks
Insecure direct object reference	Authorize every trip/booking/document ID; unguessable IDs are not sufficient [R7]
Privilege escalation	Separate trip roles from org roles; signed policy evaluation and short-lived delegations
Sensitive travel data exposure	Need-to-know field filtering; short-lived file URLs; encryption; retention and deletion
Payment / booking double-submit	Idempotency keys, ledger events, webhook replay defense, unique transaction constraints
Prompt injection / AI overreach	Tool allowlist, data provenance, user-scope evaluation, human approval, no secret access
Invite link abuse	Expiry, redemption limits, verification and revocation
Operator support overreach	Break-glass elevated access with reason, time limit and audit

Minimum controls

- MFA for organization administrators and financial approvers; SSO for enterprise tier.
- Least privilege and separation of duties for publishing, payment, refunds and supplier management.
- Encrypted transport, managed secrets, application audit log and monitored privilege changes.
- Tenant-scoped database backups and tested restore paths; document your deletion/retention model.

- Data protection processes for passports, medical/accessibility requests, minors and emergency contacts, where collected.
- Incident response playbook with owner, severity, notifications, and clear support escalation.

Jurisdiction-specific privacy, travel selling, payments, refunds, consumer protection, recordkeeping and accessibility obligations require legal and compliance review. This blueprint is a software plan, not legal advice.

21 Enterprise onboarding and administration

Company / agency workspace provisioning

32. Create an organization workspace; verify authority to represent the organization.
33. Set owner(s), billing contacts, operating region and supported currencies.
34. Invite admins and managers; configure groups/departments and role mappings.
35. Set travel policies, budget approval thresholds, cancellation workflows, and integrations.
36. Configure branded traveler notifications and document templates.
37. Run onboarding checks: pilot trip, role review, sample booking, audit export and recovery contact.

Enterprise-grade features (later phases)

Capability	When it becomes worthwhile
SSO with SAML/OIDC	Corporate teams with identity management requirements
SCIM provisioning	Large employee populations / frequent staff changes
Custom approval rules	Multiple cost centers / region-specific policy
Audit export / retention controls	Security review and finance reconciliation
Custom domain / branding	White-label agency demand and contractual support
Dedicated data/deployment tier	Enterprise residency or isolation requirements
API / webhook integrations	ERP, expense, HRIS or supplier sync

Customer support boundary

TripRaft internal operators must use purpose-limited support access, customer consent or approved break-glass flows. Internal “superadmin” is a platform operations role and should never be treated as an organization-level Owner in customer APIs.

22 Reliability, scale, and observability

Operate by measurable service boundaries

Signal	Why measure it	Initial target approach
API latency and error rate	Basic consumer and enterprise usability	Define p50 / p95 budgets per endpoint
Booking/payment reconciliation drift	Direct commercial risk	Alert on unpaid-but-confirmed / succeeded-but-unfulfilled
Failed policy checks	Detect misconfiguration and abuse	Rate + structured reason; no PII in logs
AI grounding and task success	User trust and cost control	Reviewed evaluations + agent trace IDs
Queue backlog	Notifications and workflow lag	Age threshold, retries, dead-letter queue

Signal	Why measure it	Initial target approach
Tenant resource consumption	Avoid noisy neighbors	Per-tenant quotas and budgets
Place data freshness	Avoid false travel claims	Track stale items and verified coverage

Operations design

Start with managed database backups, application performance monitoring, structured logs (request_id, tenant_id, trip_id, actor_id with privacy controls), distributed traces, deployment rollbacks and a staging environment. Measure per-tenant and per-feature costs before establishing pricing. Provide runbooks for webhook outages, supplier timeouts, deleted invitations and organization lockouts.

Scale path

Stage 1: one well-structured backend. Stage 2: move AI planning, notification workers, analytics, and search to independent scaling pools. Stage 3: add deployment stamps, regional placement and selected dedicated tenant data layers if required. Split services based on observed load and team ownership, not fashion.

23 Quality and acceptance checks

Minimum security regression suite

- User A in Company A cannot access Company B trip by changing a URL or request ID.
- Agency member cannot access a traveler document outside assigned booking/departure.
- Viewer cannot mutate itinerary or use a hidden publish endpoint.
- Treasurer cannot issue refunds without grant and approved request.
- A user removed from an organization loses tokens, jobs, websocket subscriptions and file access.
- Published itinerary cannot be overwritten by a stale draft version.
- Duplicate booking/payments requests cannot create duplicate charges or seat allocations.
- AI assistant cannot bypass resource checks using tool calls.

Feature acceptance matrix

Release surface	Acceptance criterion
Friends/family MVP	Create trip, invite users, vote, build map itinerary, track expenses, assign 3 duties
Corporate pilot	Employee request -> approval -> coordinator itinerary -> expense report
Agency pilot	Package -> departure -> available seats -> booking -> confirmation -> itinerary access
Operations	Correct per-tenant audit/backup, failure alerts, support tooling
Security	Automated cross-tenant and permission-denial tests in CI
Finance	Payment state, refund and reconciliation remain consistent under retries

Testing types

Unit tests for policy and state machines; contract tests for APIs; integration tests with provider sandboxes; end-to-end tests across all three modes; concurrent inventory/booking tests; authorization fuzzing; accessibility checks; chaos/resilience tests for queues and webhooks; and load tests by tenant type.

24 Development roadmap

Sequence the platform by product value and risk reduction. Phases are order-of-work estimates, not promised delivery dates. Each phase should ship behind feature flags, include telemetry, and pass the prior phase security gates.

Phase	Core deliverables	Exit condition
0: Foundation	Tenant model, identity, role engine, operational PostgreSQL, catalog API, design system	Cross-tenant tests pass; workspace switching works
1: Personal MVP	Create/join trips, itinerary, maps, proposals, polls, role badges, task board, expense splits	Family trip completed end-to-end
2: Corporate pilot	Org onboarding, travel requests, policy rules, approval queue, cost center, reporting	Request-to-approval audited pilot
3: Agency pilot	Package builder, departures, traveler records, invitations, seat holds, guide ops	Sample paid/non-paid departure managed reliably
4: Commerce	PSP integration, invoices/refunds, supplier states, reconciliation, support tooling	Booking and payment reconciliation tests pass
5: Enterprise scale	SSO/SCIM, branding, API/webhooks, advanced reporting, isolation tier	Security/ops readiness for bigger contracts

Prioritized engineering epics

38. Workspace context + membership APIs with deny-by-default tenant isolation.
39. Trip editor and publication versions with conflict handling.
40. Responsibilities + scoped capabilities and task assignments.
41. Catalog search and maps using stable canonical place IDs.
42. Corporate travel requests and approval engine.
43. Commercial package / departure / booking aggregate and inventory consistency.
44. Financial ledger, PSP integration, reconciliation and secure traveler data.
45. SSO, audit exports, partner integrations and white-label capability.

Non-goals for the first launch

Do not attempt full flight ticketing/GDS, multiple international payment facilitators, dynamic travel insurance, full ERP integration, enterprise self-hosting and every possible regulatory regime at once. Instead make the core data model and API boundaries extensible.

25 Worked examples and engineering decisions

Scenario A - friend who also works at an agency

Rahul logs into one identity and switches between his personal workspace and Sunrise Tours. Personal vacation data never appears in Sunrise Tours search, analytics, AI context or audit reports. In Sunrise Tours, Rahul is a staff Member + Culture Scout on one departure; he can suggest an attraction but cannot approve supplier payments or export unrelated traveler manifests.

Scenario B - paid Italy tour with 20 customers

Sunrise Tours creates the “Italy Highlights” package and two departures. An agency operator is Admin on the July departure, the accountant is Treasurer with invoice-preparation rights, and a guide is Navigator + Culture Scout. Twenty customers book seats. Each customer receives a scoped booking portal, while the agency sees departure

operations and authorized finance views. A pickup-time change is reviewed, published as a new itinerary version, and communicated to relevant customers.

Scenario C - employee company retreat

Acme Corp invites its employees through SSO, creates a retreat trip, and requires manager approval for budget exceptions. Finance tracks actual expenses; employees may see the schedule and submit receipts but cannot see coworkers' private travel documents or modify company supplier reservations.

Scenario D - canceled trip

A weather disruption affects a commercial departure. Operations logs the incident; booking states are reassessed against confirmed supplier policy, finance calculates refundable amounts, an authorized approver approves any refund, the payment provider executes the funds movement, and the customer portal shows the verified outcome. Every step is logged and recoverable.

Decision register to finalize before coding

Decision	Recommended default	Owner to confirm
Tenant definition	Personal workspace or verified organization	Product + security
Commercial merchant-of-record	Agency or authorized PSP model, not assumed	Legal + finance
Package vs departure	Separate entities	Engineering + operations
Official itinerary change gate	Owner/Admin approval + versioning	Product + agencies
Refund permission	Prepare / approve / execute separation	Finance + security
User onboarding	Global identity, workspace memberships	Product + IAM
Map / place rights	License and attribution review	Legal + data
Support staff data access	Time-limited logged grants	Security + operations

Appendix A Example permissions and workflows

Example capabilities by actor

Actor	Capabilities	Denied unless separately granted
Personal Owner	trip.create, trip.publish, trip.invite, trip.archive	Any access to company data
Trip Admin	trip.edit_draft, members.manage, tasks.assign	Organization billing admin
Treasurer (Member)	finance.record_expense, finance.prepare_reconciliation	finance.execute_refund, org.margin_read
Navigator (Member)	route.propose, itinerary.edit_logistics_draft	booking.cancel, trip.publish
Culture Scout (Member)	place.propose, itinerary.comment	supplier.modify, trip.publish
Agency Customer	booking.view_own, itinerary.view_published	manifest.export, package.edit
Corporate Approver	request.read_assigned, approval.decide	Other manager queues, company owner

Approval policy pseudocode

```
def authorize(actor, workspace, resource, action):
  if not actor.is_authenticated: return DENY
  if resource.workspace_id != workspace.id: return DENY
  if not has_valid_membership_or_guest_grant(actor, workspace, resource): return DENY
  if not entitled(workspace, action): return DENY
  if not role_or_scoped_grant_allows(actor, resource, action): return DENY
  if not resource_state_allows(resource, action): return DENY
  if requires_approval(action) and not exact_approval_exists(resource, action):
    return REQUIRE_APPROVAL
  return ALLOW
```

This demonstrates intent, not a secure drop-in authorization library. A production implementation must protect against conflicting grants, revoked memberships, stale caches, inconsistent active workspace context and privilege changes during async jobs.

Appendix B Backlog starter user stories

ID	User story	Definition of done
P-01	As a user, I can switch personal/company/agency workspaces.	Switch changes data context; no leakage
P-02	As Owner, I can invite family or friends and revoke access.	Email verified, invite expiry, audit event
P-03	As Admin, I can assign Treasurer, Navigator, Culture Scout.	Multiple badges; scoped permissions unchanged
P-04	As Member, I can propose a destination and see approval status.	Versioned proposals and actor identity
C-01	As employee, I can request company travel.	Policy checks + manager approval
C-02	As finance, I can review expenses but not change unrelated trips.	Object-scope financial filtering
A-01	As agency operator, I can publish a package and departure.	Capacity, dates, price and approval gate
A-02	As customer, I can view only my booking and itinerary.	Scoped booking access + privacy tests
A-03	As operator, I can hold a seat with expiry.	Atomic capacity, no oversell under concurrency
S-01	As security lead, I can export scoped audit logs.	Redaction and admin audit trace

Appendix C Reference notes

The cited materials describe publicly documented patterns. They are not evidence that TripRaft already implements them, nor proof that any single vendor uses the identical proposed stack.

[R1] Salesforce Architects - Platform Multitenant Architecture

https://architect.salesforce.com/docs/architect/fundamentals/guide/platform-multitenant-architecture.html

[R2] Microsoft Learn - Tenancy Models for a Multitenant Solution

https://learn.microsoft.com/en-us/azure/architecture/guide/multitenant/considerations/tenancy-models

[R3] AWS Prescriptive Guidance - SaaS authorization and API access control

https://docs.aws.amazon.com/prescriptive-guidance/latest/saas-multitenant-api-access-authorization/introduction.html

[R4] Expedia Group - Travel Agent Affiliate Program (TAAP)

https://partner.expediagroup.com/en-us/solutions/build-your-travel-experience/travel-agent-affiliate-program

[R5] SAP Concur - Available Permissions and Roles (2026 edition)

https://help.sap.com/docs/SAP_CONCUR/3211218d85314e1787f12994be30c457/1b8423e86caf1014a96b985e4783a858.html

[R6] PostgreSQL - CREATE POLICY / Row-level security

https://www.postgresql.org/docs/current/sql-createpolicy.html

[R7] OWASP - API Security Top 10 2023

https://api-security.owasp.org/editions/2023/en/0x11-t10/

[R8] Stripe Connect - Platform and marketplace payments

https://stripe.com/connect

[R9] MapLibre GL JS open source repository

https://github.com/maplibre/maplibre-gl-js

Glossary

Term	Meaning
Tenant / workspace	Boundary for customer-owned data and policy
RBAC	Role-based access control
Scoped capability	Specific permission assigned to a specific actor/resource/time
ABAC	Attribute-based access control such as policy, amount, trip state
BFF	Backend-for-frontend tailored to user experience
RLS	Database row-level security
Merchant of record	Entity contractually responsible for selling, collecting and various transaction obligations
Idempotency	Repeating an operation has no duplicate business effect
Departure	Scheduled instance of a reusable tour package
Canonical place ID	Stable destination catalog reference used in an itinerary

FINAL ARCHITECTURAL RECOMMENDATION

One TripRaft platform, one global user account, isolated personal/organization workspaces, four base trip roles, three assignable trip responsibilities, approval-controlled commercial workflows, and a modular, tenant-aware backend. Add specialized experiences without cloning the underlying product.

END OF MASTER BLUEPRINT